AUDITORÍA DE SISTEMAS · GRUPO C · AVANCE

Agente Supervisor de Consentimientos

Un agente de IA que audita si una empresa obtiene, registra y permite retirar el consentimiento sobre datos personales, según la ISO/IEC 27701:2025 y la Ley N.° 29733.

Universidad Nacional de San Agustín · Escuela Profesional de Ingeniería de Sistemas · 2026

Cómo nos repartimos la exposición

DANIELA

Contexto y diseño

Resumen de la primera entrega, el problema, las normas y el diseño del agente.

Diapositivas 1 a 7

JHASTYN

Arquitectura y orquestación

Las cuatro capas, el flujo automático, la búsqueda híbrida, el skill y los controles de calidad.

Diapositivas 8 a 14

DANIEL

Demostración y resultados

Las mejoras, el agente funcionando en vivo, los resultados de los 5 casos y el cierre.

Diapositivas 15 a 21

Sigue la rúbrica: diseño de agente → orquestación y automatización → proyecto agéntico → resultado

RESUMEN DE LA PRIMERA ENTREGA

De la propuesta al agente funcionando

Primera entrega: el diseño

- TIF con la propuesta del agente
- RAG híbrido y patrón Fail-Fast
- Caso de prueba TiendaAndina
- Prototipo básico por consola

Esta entrega: el agente

- Agente completo y skill en OpenCode
- Revisión humana y seguridad
- Panel web e informe en PDF
- 5 casos y 46 pruebas

EL PROBLEMA

Auditar el consentimiento a mano es lento y propenso a errores

Mucha documentación

Formularios, políticas de privacidad y registros que hay que contrastar control por control y artículo por artículo.

Excepciones legales

El Art. 14 de la Ley 29733 exime del consentimiento en ciertos casos; ignorarlo genera no conformidades falsas.

Un LLM solo no basta

Un modelo de lenguaje puede inventar normas o hechos: un dictamen de auditoría necesita fundamento verificable.

OBJETIVO DEL AGENTE

Evaluar una evidencia documental y emitir un dictamen por dominio —Conforme, No Conforme o No Aplica— con la norma aplicada, la cita de la evidencia y las medidas correctivas.

ISO/IEC 27701:2025

Controles A.1.2.2, A.1.2.4, A.1.2.5, A.1.3.3, A.1.3.4 y A.1.3.5

Ley N.° 29733

Art. 5 (consentimiento), 13.5, 14 (excepciones) y 18 (información)

RÚBRICA 1 · DISEÑO DE AGENTE

Objetivo, datos, contexto y herramientas

Objetivo

Dictaminar el cumplimiento del ciclo del consentimiento: obtención, registro, modificación y revocación.

Datos

Corpus normativo (20 fragmentos ISO + Ley) y las evidencias a auditar, cargadas como texto en evidencias/.

Contexto

Ficha del agente (identidad, reglas, formato de salida), reglas de auditoría y catálogo de excepciones del Art. 14.

Herramientas

5 herramientas MCP: recuperar normas, verificar excepciones, analizar evidencia, emitir informe y auditoría completa.

LOS DATOS DEL AGENTE

La norma se divide por artículo y por control

Cada **artículo** de la ley es un fragmento; el **Art. 14** se divide numeral por numeral, con su cabecera.

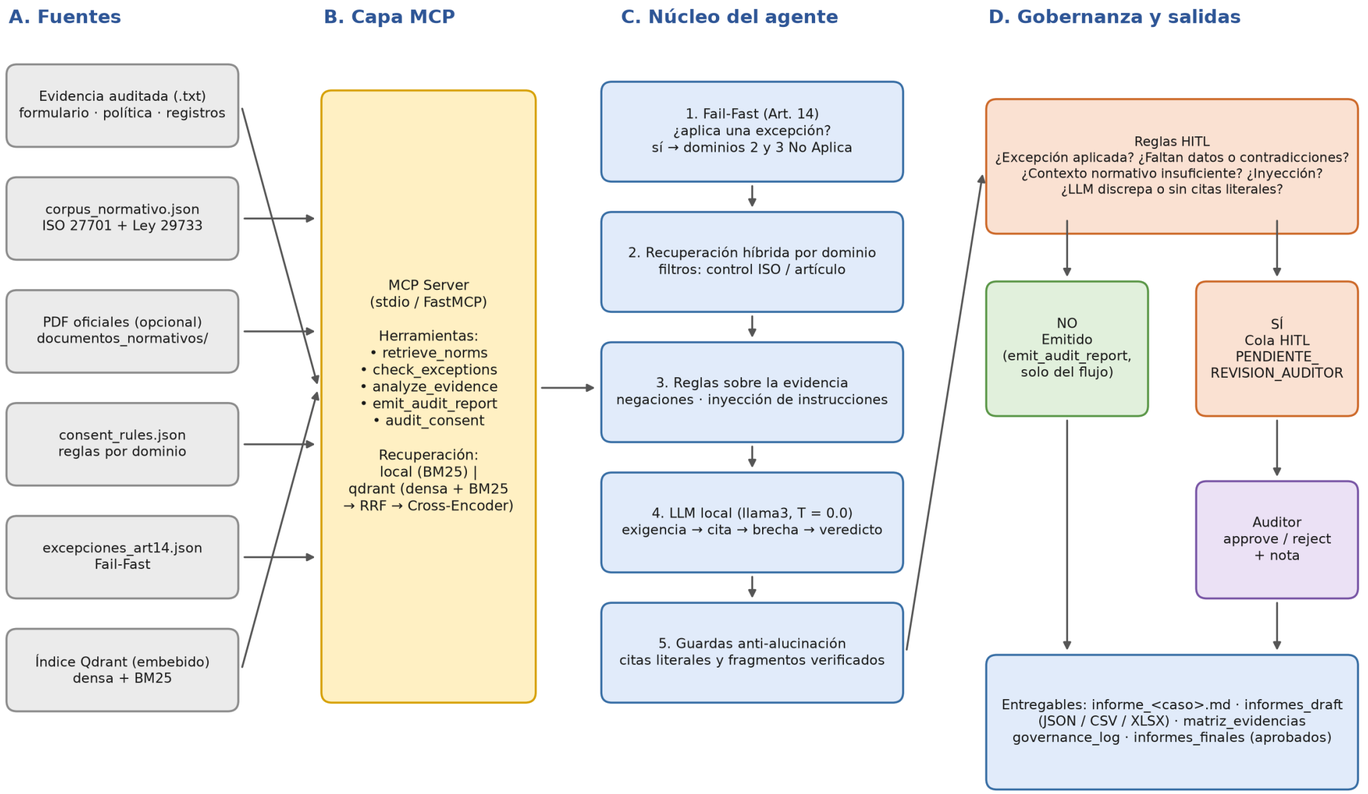
Cada **control** de la ISO es un fragmento: Anexo A = requisito, Anexo B = guía.

Así una excepción nunca queda separada de la regla que modifica.

Metadato	Ejemplo
norma	Ley N.° 29733
articulo / numeral	14 · numeral 5
control	A.1.2.5
naturaleza	requisito · guía · excepción
seccion_jerarquica	Anexo A > A.1.2.5

ARQUITECTURA DEL AGENTE

Cuatro capas, todo corre en el equipo del auditor



RÚBRICA 2 · ORQUESTACIÓN Y AUTOMATIZACIÓN

Un flujo automático en seis pasos

1

Fail-Fast

¿Aplica una excepción del Art. 14?

2

Búsqueda híbrida

Recupera la norma de cada dominio

3

Reglas

Detecta brechas en la evidencia

4

LLM local

Razona en 4 pasos (llama3)

5

Guardas

Verifica citas y normas

6

HITL e informe

Emite o pasa al auditor

Todo se ejecuta con un solo comando y se repite para cada evidencia: **python run_demo.py**

PASO 1 · FAIL-FAST

Primero las excepciones, después los controles

Si aplica una excepción

Ej.: apertura de una cuenta bancaria (relación contractual, Art. 14 num. 5).

Obtención y revocación del consentimiento → **No Aplica**. El deber de información se evalúa igual.

Si no aplica

Ej.: suscripción a promociones de una tienda web.

El consentimiento es exigible → se evalúan los tres dominios completos.

Una excepción **nunca** ampara publicidad, marketing ni perfilamiento. Así se evitan no conformidades falsas.

PASO 2 · RAG HÍBRIDO

Búsqueda por significado y por palabra exacta

ETAPA 1 · DENSA

Embeddings multilingües

«Casilla premarcada» se relaciona con «consentimiento inequívoco» aunque no compartan palabras.

ETAPA 2 · DISPERSA

BM25

Coincidencias exactas: «Art. 14», «A.1.3.5», «revocar», «lavado de activos».

ETAPA 3 · FUSIÓN

RRF + Cross-Encoder

Se combinan ambas listas y un re-ranker elige los mejores fragmentos para el LLM.

Base vectorial **Qdrant** (embebida, sin Docker) con filtros de metadatos: cada dominio busca solo en sus controles y artículos.

RÚBRICA 2 · SKILLS, AGENTES Y FLUJOS

Cómo se coordinan las piezas

Pieza	Qué hace
Agente (consent-supervisor)	Identidad, protocolo y reglas; decide qué herramienta usar en cada paso
Skill (consent-audit)	El proceso de auditoría paso a paso, reutilizable
Servidor MCP	Expone las 5 herramientas para opencode u otros agentes
Salida JSON estándar	Mismo formato que el agente Data Bridge del grupo, consumible por otros agentes
Automatización	run_demo.py audita todas las evidencias y genera todos los entregables

SEGUNDO ENTREGABLE · DEL PROMPT AL SKILL

El skill consent-audit funcionando en OpenCode

Qué se comprobó

- OpenCode activó el skill solo, ante una solicitud que no lo nombraba
- Ejecutó la auditoría por consola y por la herramienta MCP
- El resultado quedó pendiente del auditor, con huella y ticket

Dos IA distintas

Asistente de OpenCode: modelo en línea (ChatGPT), que conversa y usa el skill.

Motor del agente: reglas, búsqueda híbrida y Llama 3 local en Ollama, que emiten el dictamen.

PASOS 5 Y 6 · CONTROL DE CALIDAD

El LLM opina; las reglas y el auditor deciden

Guardas anti-alucinación

- Solo valen citas copiadas tal cual de la evidencia
- Cada norma citada debe haber sido recuperada
- Si el LLM contradice a las reglas, se mantiene el dictamen de las reglas

Pasa al auditor (HITL) si…

- se aplicó una excepción del Art. 14
- faltan datos o hay contradicciones
- hay instrucciones maliciosas
- el LLM discrepa o no cita nada literal

SEGUNDO ENTREGABLE · PRUEBAS DE SEGURIDAD

Seis fallas detectadas y corregidas

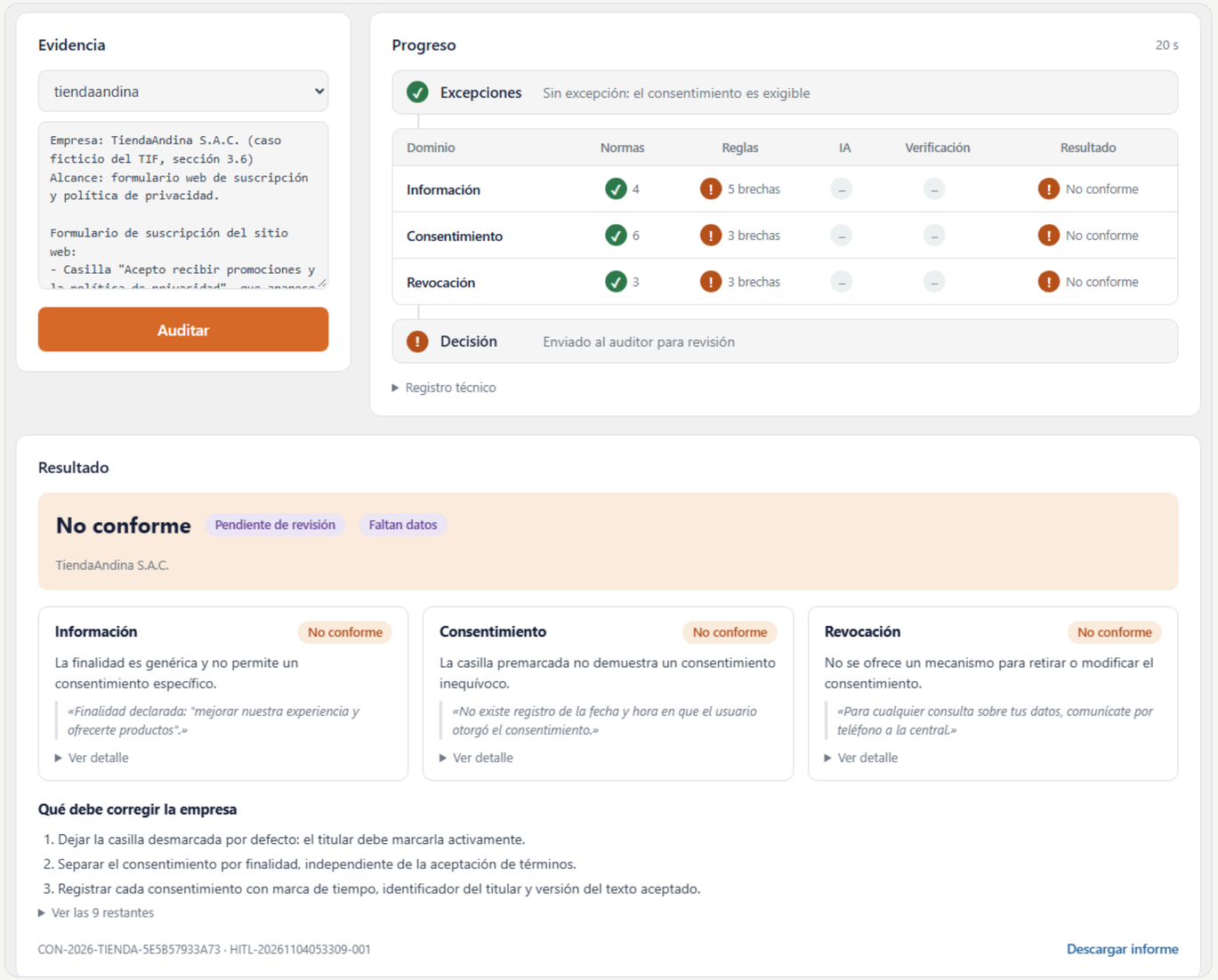
Falla de la primera versión	Corrección
«Destinatarios:» vacío contaba como cumplimiento	Cada requisito exige contenido real
Una cita con la negación invertida pasaba	Solo citas literales
Se podía emitir un informe inventado	Solo se emiten informes del propio flujo
Dos auditorías de una empresa compartían ID	ID único por auditoría
El ticket no quedaba guardado en la cola	Se guarda desde su creación
«Centro de diagnóstico» activaba la excepción de salud	El nombre de la empresa no es prueba

DEMOSTRACIÓN EN VIVO

El panel del auditor

1. Elegir el caso y pulsar **Auditar**
2. Ver los pasos encenderse
3. Leer el dictamen por dominio
4. Abrir el informe en **PDF**
5. **Aprobar** o **rechazar** en la cola

python dashboard.py · http://127.0.0.1:8765



RÚBRICA 3 · PROYECTO AGÉNTICO

Una solución integrada que funciona de punta a punta

1 · CARGAR LA DATA

Se sube manualmente: el formulario o la política se guarda como **.txt** o se pega en el panel

2 · AUDITAR

Desde el panel web o por consola, con la búsqueda híbrida y Llama 3 locales

3 · RESULTADOS

Informe en PDF, Excel, matriz de evidencias y cola del auditor

46 pruebas automáticas aprobadas y una validación reproducible de los 5 casos.

RESULTADO DEL PROYECTO

Cinco casos, cinco comportamientos esperados

Caso	Qué prueba	Dictamen	Estado
TiendaAndina	El caso del TIF	No Conforme en los 3 dominios	Al auditor (faltan datos)
Banco Andino	Excepción contractual (Art. 14)	Dominios 2 y 3 No Aplica	Al auditor (excepción)
LibreríaSur	Formulario bien diseñado	Conforme en los 3 dominios	Emitido (al auditor si llama3 discrepa)
ClubFit	Instrucción maliciosa oculta	No Conforme; ataque detectado	Al auditor (inyección)
Formulario incompleto	Encabezados sin contenido	No Conforme en los 3 dominios	Al auditor (faltan datos)

EL CASO DEL TIF · TIENDAANDINA S.A.C.

El informe reproduce la tabla 3.7 del TIF

Dominio	Evidencia citada	Dictamen	Medida principal
1. Información y propósito	«mejorar nuestra experiencia y ofrecerte productos»	**No Conforme**	Finalidades concretas y aviso completo
2. Obtención y registro	Casilla «Acepto recibir promociones…» premarcada	**No Conforme**	Casilla desmarcada y registro con fecha y hora
3. Modificación y revocación	«comunícate por teléfono a la central»	**No Conforme**	Baja en línea por el mismo canal
4. Excepciones legales	Fines de marketing	Excepción no aplicable	Ninguna; se evalúa todo

Cada dictamen cita el fragmento normativo usado. El informe queda **pendiente del auditor**: no consta un canal de derechos ni un mecanismo de baja.

LO QUE APRENDIMOS AL PROBARLO

Un LLM local no basta como juez

8/10

aciertos de llama3

6/10

aciertos de llama3.1

Por eso el diseño

Los modelos de 8B tienden a decir «No Conforme» en casos que cumplen. El LLM aporta el razonamiento; las reglas verificables y el auditor tienen la última palabra.

Prueba: 4 decisiones de Fail-Fast + 6 dictámenes por dominio, ejecutada en el equipo del grupo.

CONCLUSIONES Y TRABAJO PENDIENTE

Un agente funcional, con el auditor al centro

Logrado

- Agente diseñado y skill funcionando en OpenCode
- Flujo automático con Fail-Fast y RAG híbrido
- Panel web, informe PDF y 46 pruebas
- Seis fallas de seguridad corregidas

Pendiente (tercera unidad)

- Orquestarlo con los otros agentes del grupo
- Texto literal de la ISO y Art. 14 verificado
- Reglas más amplias y modelos más precisos
- Casos reales revisados por un experto

Gracias · Preguntas